

PART 1: WEBSITE SECURITY REVIEW

Choose any website or your own application.

Analyze the following:

- 1. Login Page**
- 2. Registration Page**
- 3. Forgot Password Functionality**
- 4. Contact Form**
- 5. Search Functionality**
- 6. User Profile Section**

Create a table:

Feature | Purpose | Security Risks | Recommendations

PART 2: SECURITY FEATURE ANALYSIS

Identify and document the following security features:

- HTTPS**
- CAPTCHA**
- Two-Factor Authentication (2FA)**
- Email Verification**
- Password Complexity Rules**
- Session Timeout**
- Password Reset Mechanism**

Take screenshots wherever applicable.

PART 3: SECURITY OBSERVATIONS

For the selected website, answer:

- 1. What sensitive information does the application handle?**
- 2. Which security controls are implemented?**
- 3. What are the possible security risks?**
- 4. What improvements would you recommend?**

PART 4: RISK CLASSIFICATION

Categorize your observations into:

- Critical Risk**
- High Risk**
- Medium Risk**
- Low Risk**
- Informational**

Explain why each issue belongs to that category.

PART 5: PROFESSIONAL REPORT

Prepare a professional security assessment report containing:

- 1. Executive Summary**
- 2. Scope of Assessment**
- 3. Methodology**
- 4. Security Features Identified**
- 5. Observations**
- 6. Risk Classification**
- 7. Recommendations**
- 8. Conclusion**

Choose any popular website and compare it with your own website.

Compare:

- **Authentication Security**
- **Password Policy**
- **User Verification**
- **Session Management**
- **Additional Security Features**

Create a comparison table.

SUBMISSION REQUIREMENTS

- **PDF or Word Document**

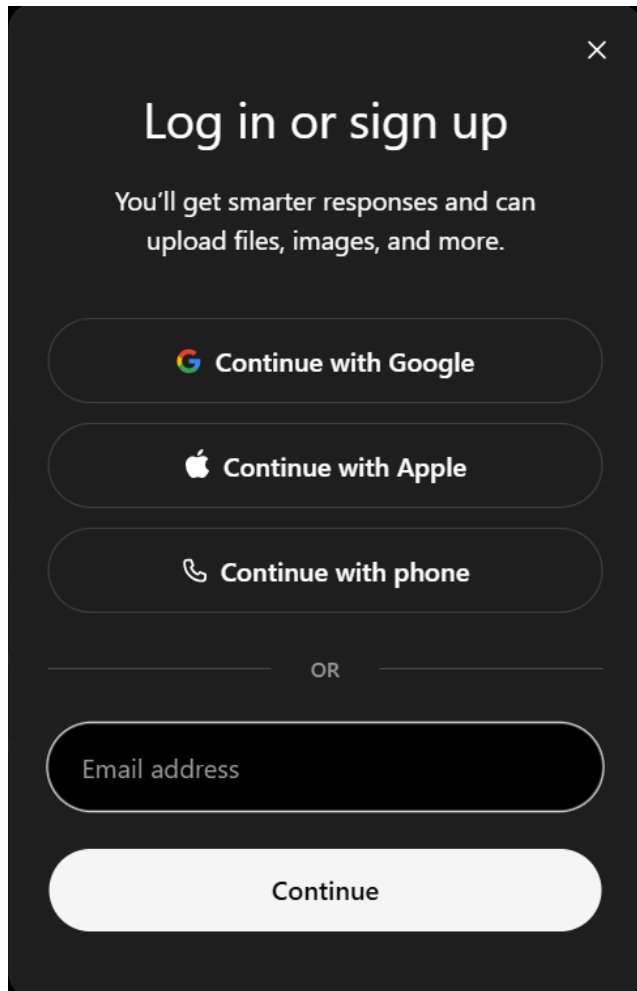
PART 1: WEBSITE SECURITY REVIEW

The selected website for security assessment is **ChatGPT**. The following user-facing functionalities were reviewed:

Feature	Purpose	Security Risks	Recommendations
Login Page	Allows users to access their accounts	Brute force attacks, credential stuffing	Implement stronger rate limiting and CAPTCHA
Registration Page	Allows new users to create accounts	Fake registrations, weak passwords	Enforce strong password policy and email verification
Forgot Password Functionality	Helps users recover their accounts	Token interception, phishing	Use short-lived reset links and email confirmation
Contact Form / Help Center	Allows users to get support	Spam, malicious input	Use CAPTCHA and sanitize inputs
Search Functionality	Helps users search chats/help articles	Information leakage	Restrict unauthorized access
User Profile Section	Allows account and security settings management	Unauthorized profile changes	Require re-authentication for sensitive actions

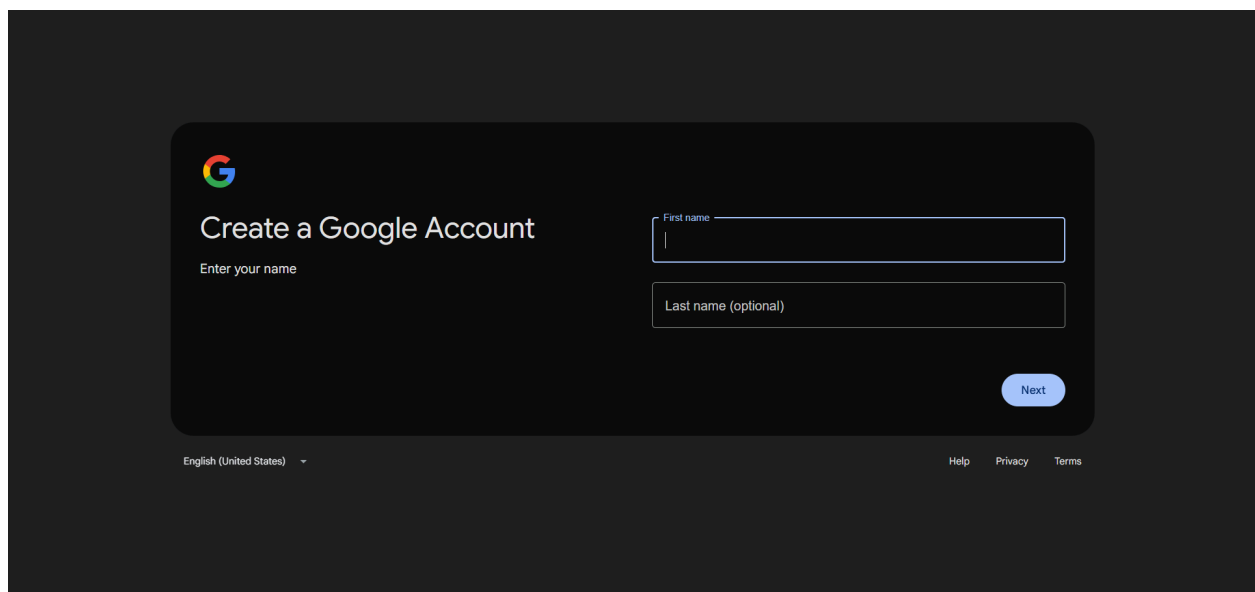
Screenshot Placement for Part 1:

Login Page



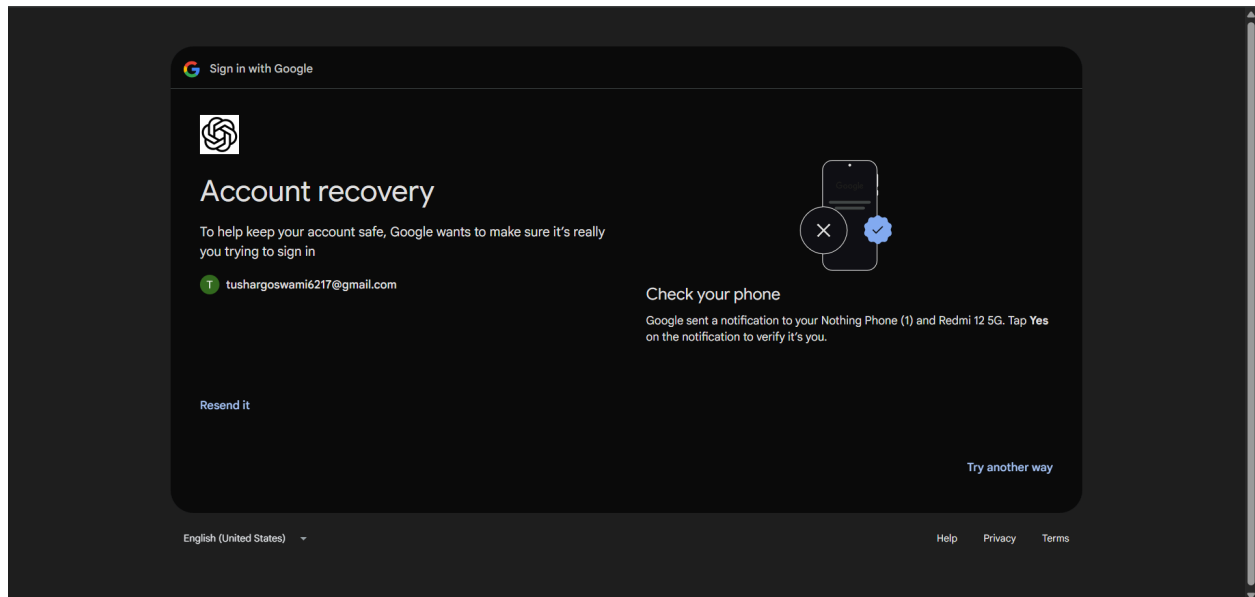
A dark-themed login modal with a close button (X) in the top right corner. The title "Log in or sign up" is centered at the top. Below it, a subtitle reads: "You'll get smarter responses and can upload files, images, and more." There are three large, rounded buttons stacked vertically: "Continue with Google" (with the Google logo), "Continue with Apple" (with the Apple logo), and "Continue with phone" (with a phone icon). Below these buttons is a horizontal line with the word "OR" in the center. Under the line is a text input field labeled "Email address". At the bottom is a large, light-colored "Continue" button.

Registration Page

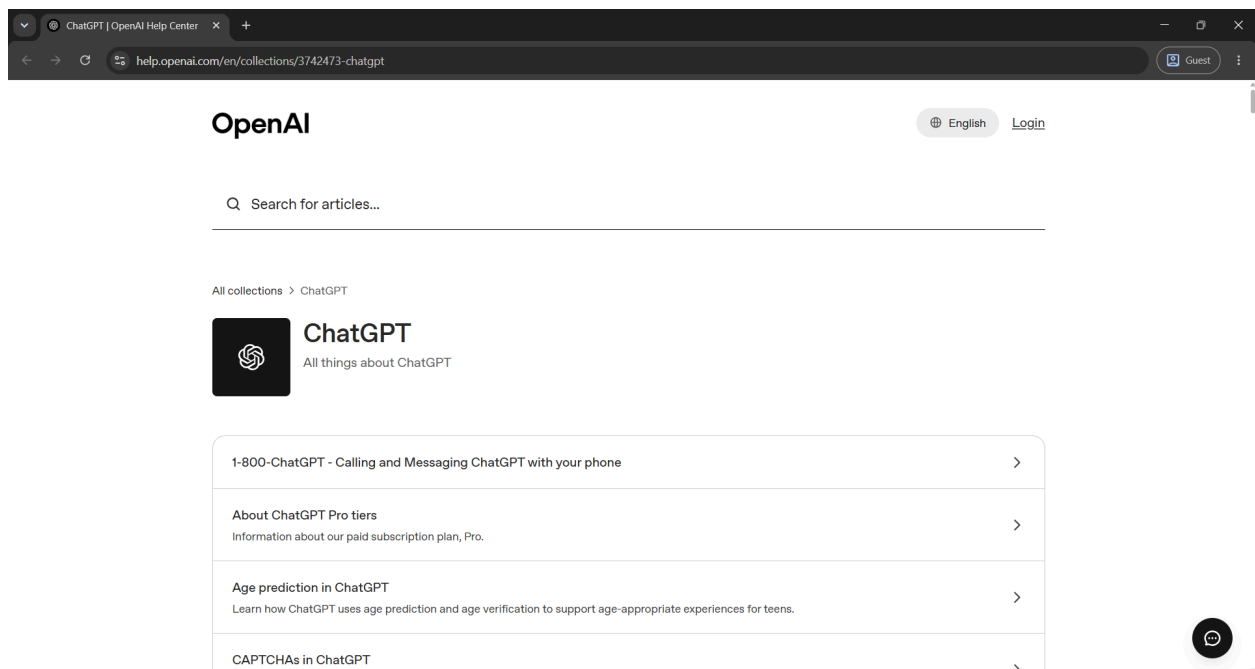


A dark-themed registration page. On the left, the Google logo is above the text "Create a Google Account" and "Enter your name". On the right, there are two text input fields: "First name" and "Last name (optional)". Below these fields is a blue "Next" button. At the bottom left, there is a language selector showing "English (United States)". At the bottom right, there are links for "Help", "Privacy", and "Terms".

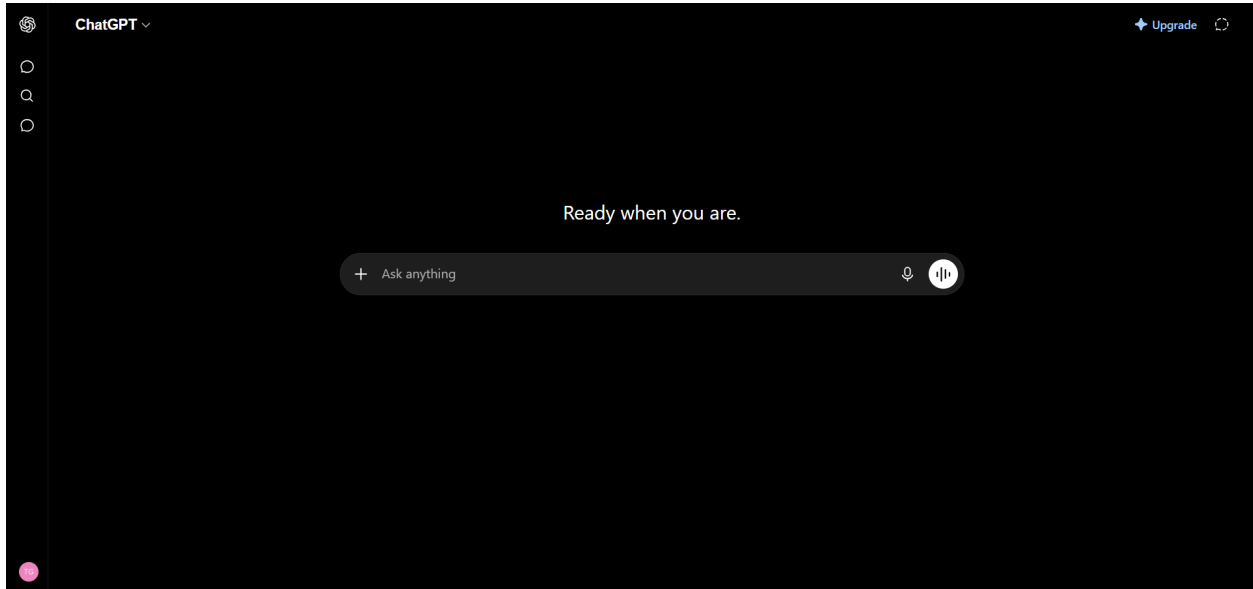
Forgot Password Functionality



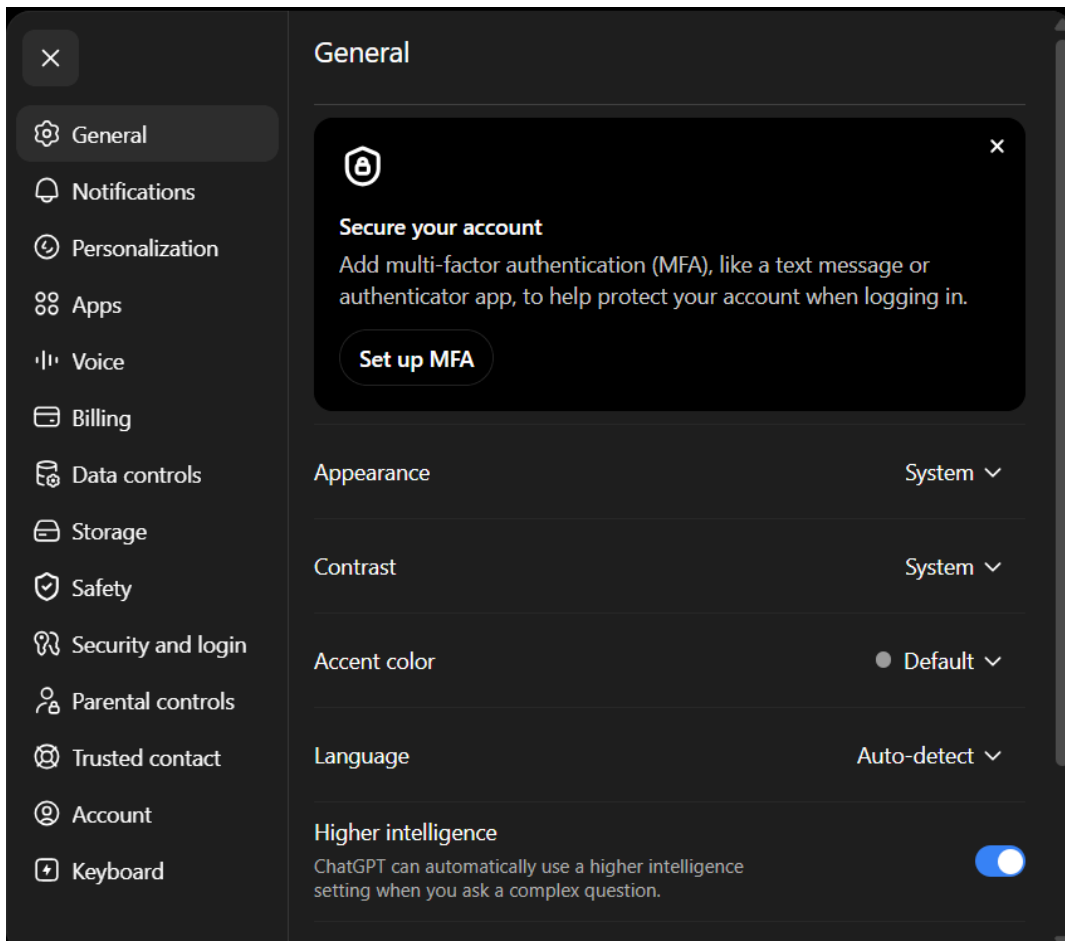
Contact Form / Help Center



Search Functionality



User Profile Section



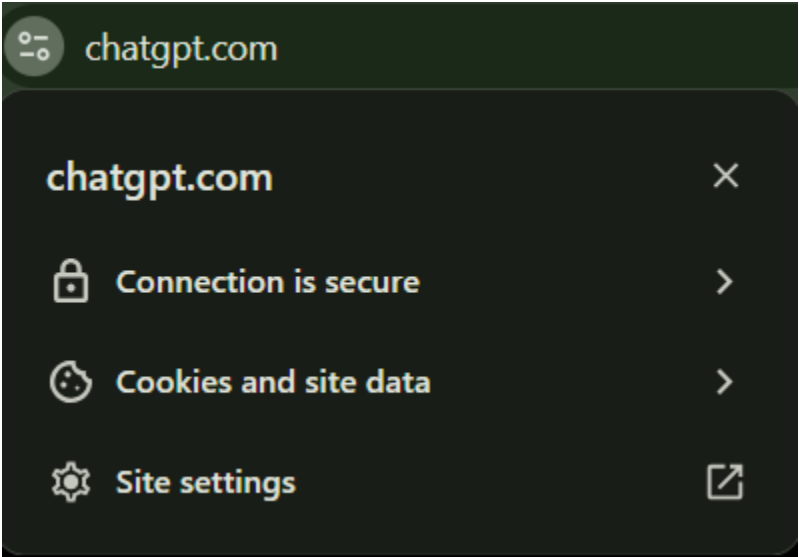
PART 2: SECURITY FEATURE ANALYSIS

The following security features were identified:

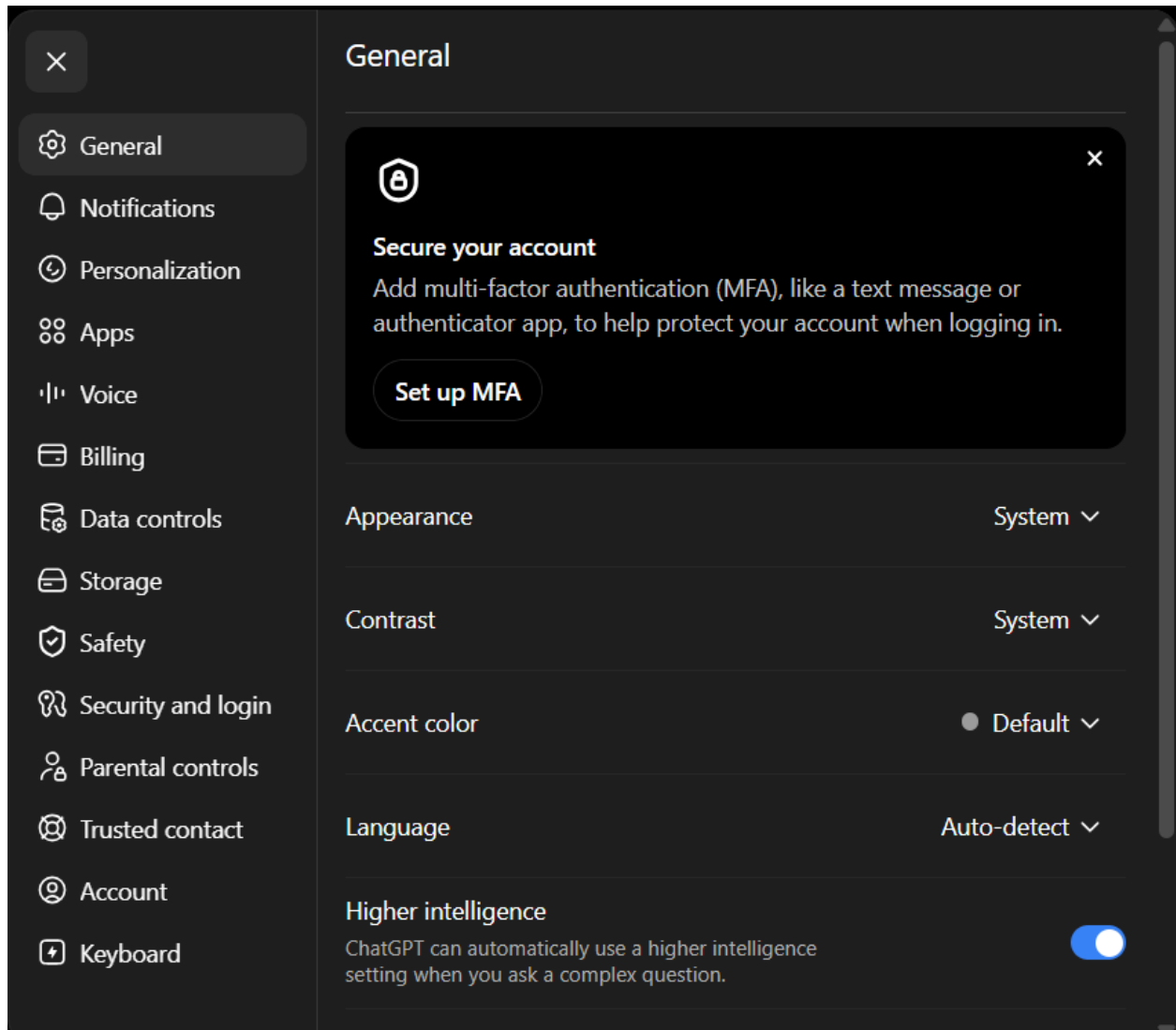
Security Feature	Status	Description
HTTPS	Implemented	Encrypts communication between user and server
CAPTCHA	Partially observed	Mentioned in help center, used conditionally
Two-Factor Authentication (2FA)	Implemented	MFA option available in settings
Email Verification	Implemented	Google-authenticated email verification
Password Complexity Rules	Implemented	Password input field with secure handling
Session Timeout	Implemented	Session expires after inactivity
Password Reset Mechanism	Implemented	Recovery options available

Screenshot Placement for Part 2

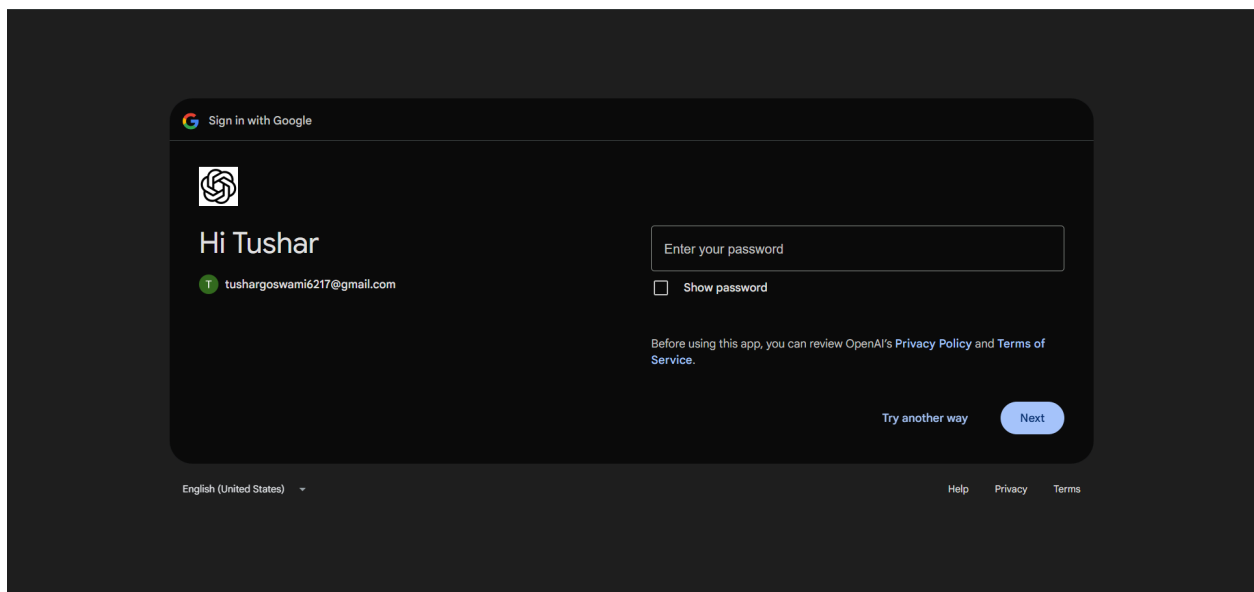
HTTPS



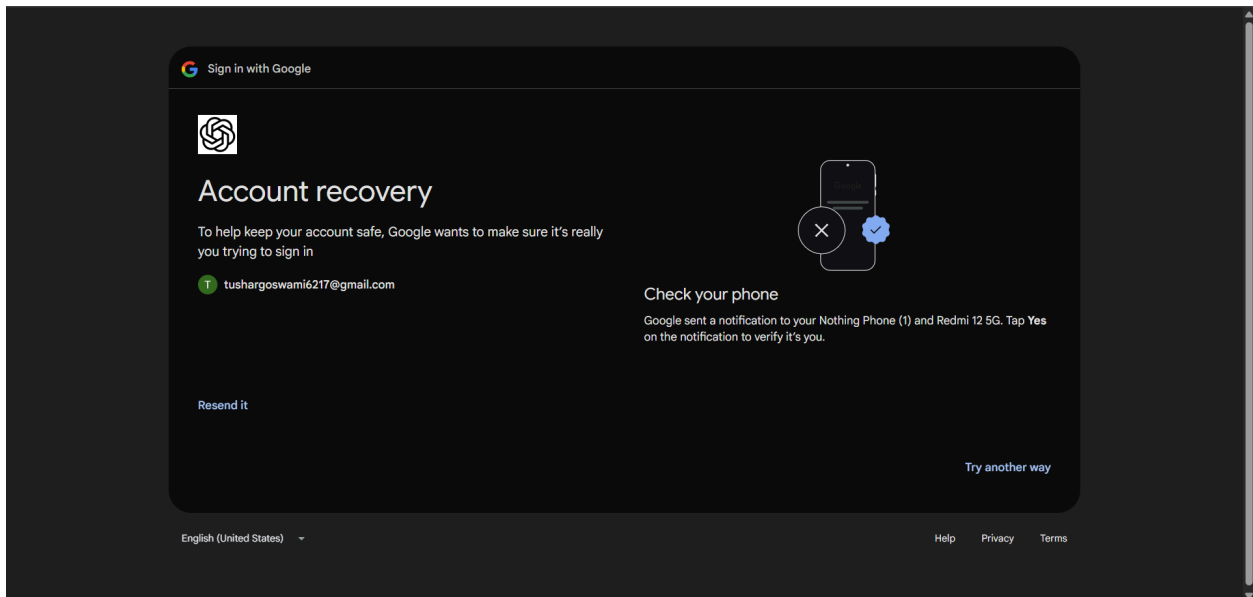
2FA/MFA



Password field



Password reset mechanism



PART 3: SECURITY OBSERVATIONS

1. What sensitive information does the application handle?

The application handles:

- Email addresses
- Passwords
- User chat history
- Personal preferences
- Billing information (for premium users)
- Authentication tokens

2. Which security controls are implemented?

The website implements:

- HTTPS encryption
- Multi-Factor Authentication (MFA)
- Email verification
- Password recovery system
- Session management
- Secure cookies
- Access control mechanisms

3. What are the possible security risks?

Potential risks include:

- Session hijacking
- Phishing attacks
- Credential stuffing
- Unauthorized account access
- Browser token theft
- Weak user-created passwords

4. What improvements would you recommend?

Recommended improvements:

- Mandatory MFA for all users
- Stronger brute force detection
- CAPTCHA after repeated failed logins
- Device login alerts
- Better anomaly detection for suspicious logins

PART 4: RISK CLASSIFICATION

Risk Level	Issue	Reason
Critical Risk	Session Hijacking	Can lead to full account takeover
High Risk	Credential Theft	Attackers can access user data
Medium Risk	Weak Passwords	Easier for brute force attacks
Low Risk	Search Data Exposure	Limited if access controls exist
Informational	HTTPS Enabled	Indicates secure encrypted communication

PART 5: PROFESSIONAL REPORT

Executive Summary

This report evaluates the security posture of the ChatGPT web application by analyzing major user-facing functionalities including authentication, account recovery, support systems, and profile settings. The goal is to identify security features, potential risks, and suggest improvements.

Scope of Assessment

The assessment covers:

- Authentication pages
- Registration process
- Account recovery
- User settings
- Support/help center
- Search functionality
- Session management

Methodology

The following methodology was used:

1. Manual browsing and feature inspection
2. Security control identification
3. Functional analysis
4. Risk categorization
5. Observation-based reporting

Security Features Identified

The following features were found:

- HTTPS encryption
- Multi-Factor Authentication
- Password-based authentication
- Email verification
- Account recovery system
- Session expiration
- Conditional CAPTCHA

Observations

The website has strong authentication mechanisms and follows modern security practices. The implementation of HTTPS, MFA, and recovery systems improves security significantly. However, making MFA mandatory could further reduce risks.

Risk Classification

Most risks are medium to low due to strong security controls, but account compromise through phishing remains a serious threat.

Recommendations

- Make MFA mandatory
- Improve login anomaly detection
- Add CAPTCHA after failed login attempts
- Provide login notifications
- Enforce stronger password rules

Conclusion

The ChatGPT platform demonstrates strong security architecture with secure authentication, encrypted communication, and account protection mechanisms. While the overall security posture is strong, additional proactive controls can improve resistance against evolving threats.

Comparison: Popular Website vs Own Website

(Own website example: **College Student Portal**)

Feature	ChatGPT	College Student Portal
Authentication Security	Google OAuth + Email Login	Basic username/password
Password Policy	Strong password handling	Often weak or minimal
User Verification	Email verification + OAuth	Usually only registration
Session Management	Auto timeout + secure tokens	Basic cookie sessions
Additional Security Features	MFA, HTTPS, recovery options	Limited security features

